

AMENDMENT OF SOLICITATION/MODIFICATION OF CONTRACT		BPA NO.	1. CONTRACT ID CODE	PAGE 1	OF 61	PAGES
2. AMENDMENT/MODIFICATION NUMBER A00001		3. EFFECTIVE DATE	4. REQUISITION/PURCHASE REQ. NUMBER		5. PROJECT NUMBER (if applicable) VA-26-00012979	
6. ISSUED BY Department of Veterans Affairs Technology Acquisition Center 23 Christopher Way Eatontown NJ 07724		CODE	7. ADMINISTERED BY (If other than Item 6) Department of Veterans Affairs Technology Acquisition Center 23 Christopher Way Eatontown NJ 07724		CODE	
8. NAME AND ADDRESS OF CONTRACTOR (Number, street, county, State and ZIP Code) To all Offerors/Bidders			(X)	9A. AMENDMENT OF SOLICITATION NUMBER 36C10B26R0006		
			☒	9B. DATED (SEE ITEM 11) 03-20-2026		
			☐	10A. MODIFICATION OF CONTRACT/ORDER NUMBER		
				10B. DATED (SEE ITEM 13)		
CODE		FACILITY CODE				
11. THIS ITEM ONLY APPLIES TO AMENDMENTS OF SOLICITATIONS						
☒ The above numbered solicitation is amended as set forth in Item 14. The hour and date specified for receipt of Offers ☒ is extended, ☐ is not extended. Offers must acknowledge receipt of this amendment prior to the hour and date specified in the solicitation or as amended, by one of the following methods: (a) By completing Items 8 and 15, and returning <u>1</u> copies of the amendment; (b) By acknowledging receipt of this amendment on each copy of the offer submitted; or (c) By separate letter or electronic communication which includes a reference to the solicitation and amendment numbers. FAILURE OF YOUR ACKNOWLEDGMENT TO BE RECEIVED AT THE PLACE DESIGNATED FOR THE RECEIPT OF OFFERS PRIOR TO THE HOUR AND DATE SPECIFIED MAY RESULT IN REJECTION OF YOUR OFFER. If by virtue of this amendment you desire to change an offer already submitted, such change may be made by letter or electronic communication, provided each letter or electronic communication makes reference to the solicitation and this amendment, and is received prior to the opening hour and date specified. <u>Monday, April 6, 2026, 3:00 p.m. EST</u>						
12. ACCOUNTING AND APPROPRIATION DATA (If required)						
13. THIS ITEM APPLIES ONLY TO MODIFICATIONS OF CONTRACTS/ORDERS, IT MODIFIES THE CONTRACT/ORDER NO. AS DESCRIBED IN ITEM 14.						
CHECK ONE	A. THIS CHANGE ORDER IS ISSUED PURSUANT TO: (Specify authority) THE CHANGES SET FORTH IN ITEM 14 ARE MADE IN THE CONTRACT ORDER NO. IN ITEM 10A.					
☐	B. THE ABOVE NUMBERED CONTRACT/ORDER IS MODIFIED TO REFLECT THE ADMINISTRATIVE CHANGES (such as changes in paying office, appropriation date, etc.) SET FORTH IN ITEM 14, PURSUANT TO THE AUTHORITY OF FAR 43.103(b).					
☐	C. THIS SUPPLEMENTAL AGREEMENT IS ENTERED INTO PURSUANT TO AUTHORITY OF:					
☐	D. OTHER (Specify type of modification and authority)					
E. IMPORTANT: Contractor ☐ is not, ☐ is required to sign this document and return _____ copies to the issuing office.						
14. DESCRIPTION OF AMENDMENT/MODIFICATION (Organized by UCF section headings, including solicitation/contract subject matter where feasible.) See Continuation Page.						
Except as provided herein, all terms and conditions of the document referenced in Item 9A or 10A, as heretofore changed, remains unchanged and in full force and effect.						
15A. NAME AND TITLE OF SIGNER (Type or print)			16A. NAME AND TITLE OF CONTRACTING OFFICER (Type or print) Meghan McCloskey Contracting Officer			
15B. CONTRACTOR/OFFEROR _____ (Signature of person authorized to sign)		15C. DATE SIGNED	16B. UNITED STATES OF AMERICA _____ (Signature of Contracting Officer)		16C. DATE SIGNED	

CONTINUATION PAGE:

The purpose of Amendment A00001 is to effect the following changes:

1. Provide the Government's response to questions proposed by Vendors.
2. Extend the solicitation due date until Monday, April 6, 2026, 3:00 p.m. Eastern Standard Time.
3. Section A.2(iv) hereby incorporates revisions as referenced below on page 3. See revisions highlighted in yellow.
4. Section B.1(3)(c) is hereby revised to clarify that invoicing shall occur after Government acceptance of deliverables under individual Task Orders, as defined in the applicable Task order. See revisions in red strikethrough and highlighted in yellow.
5. Section B.3, Paragraph 5.1.6, TECHNICAL SUPPORT, of the Performance Work Statement (PWS) hereby incorporates revisions as referenced below on page 15. See revisions in highlighted in yellow.
6. Except as described herein, all other terms and conditions remain unchanged and in full force and effect.

A.2 COMBINED SYNOPSIS/SOLICITATION

This is a combined synopsis/solicitation for commercial products or commercial services prepared in accordance with part 12. This announcement constitutes the only solicitation. Offers are being requested and a separate written solicitation will not be issued.

- i. Solicitation number 36C10B26R0006 is issued as a Request for Proposal (RFP) for Ambient Scribe.
- ii. This acquisition is not set-aside for small business concerns. This solicitation incorporates provisions and clauses by reference. The full text of provisions and clauses may be accessed electronically at www.acquisition.gov.
- iii. See Section B.2 below for the Price Schedule.
- iv. The purpose of this Indefinite Delivery Indefinite Quantity (IDIQ) contract is to provide a Commercial-Off-the-Shelf (COTS), cloud-based, ambient scribe solution to transcribe clinical encounters, generate notes, and other Artificial Intelligence (AI) advanced functionalities to improve the efficiency of medical care utilizing a Software as a Service (SaaS) delivery model with AI techniques and technologies. This solution shall integrate with VA's Electronic Health Record (EHR) systems and workflows so providers can initiate encounter recordings. This mitigates the need for manual entry of patient identifying information and enables automatic insertion of draft notes into EHR. Consistent with this SaaS delivery model, standard license-based access controls, including expiration of access upon the end of a subscription term, are permitted and shall not be considered "disabling software code" under Section A.4(4), provided Government access to its data is not impaired.
- v. This is an IDIQ Multiple Award Task Order (MATO) contract. Individual Task Orders (TO) shall be issued on a Firm-Fixed-Price basis. The ordering period for the basic contract shall be 5-years following the date of award.
- vi. See Section E for the incorporated provisions.
- vii. See Section C for the incorporated clauses.
- viii. Any questions/concerns shall be submitted by March 26, 2026 by 3:00 p.m. EST with the subject line "Questions – 36C10B26R0006 – Ambient Scribe" to: Brandon Caltabilota, Contract Specialist at Brandon.Caltabilota@va.gov and Meghan McCloskey, Contracting Officer at Meghan.McCloskey@va.gov.

B.1 CONTRACT ADMINISTRATION DATA

(continuation from Standard Form 1449, Block 18A.)

1. Contract Administration: All contract administration matters will be handled by the following individuals:
 - a. CONTRACTOR: TBD
 - b. GOVERNMENT: Contracting Officer 36C10B, Meghan McCloskey
Department of Veterans Affairs
Office of Procurement, Acquisition and Logistics
Technology Acquisition Center
23 Christopher Way
Eatontown, NJ 07724
2. CONTRACTOR REMITTANCE ADDRESS: All payments by the Government to the contractor will be made in accordance with:

[X] 52.232-33, Payment by Electronic Funds Transfer – System for Award Management

[] 52.232-36, Payment by Third Party
3. INVOICES: Invoices shall be submitted in arrears:
 - a. Quarterly []
 - b. Semi-Annually []
 - c. Other [X] After Government acceptance of deliverables under individual Task Orders, ~~in Section~~ as defined in the applicable Task Order.
4. GOVERNMENT INVOICE ADDRESS: All Invoices from the contractor shall be submitted electronically in accordance with VAAR Clause 852.232-72 Electronic Submission of Payment Requests.
5. ACKNOWLEDGMENT OF AMENDMENTS: The offeror acknowledges receipt of amendments to the Solicitation numbered and dated as follows:

AMENDMENT NO	DATE

B.3 PERFORMANCE WORK STATEMENT



PERFORMANCE WORK STATEMENT (PWS) DEPARTMENT OF VETERANS AFFAIRS

Veterans Health Administration
Digital Health Office

Ambient Scribe

Date: ~~February 27, 2026~~ April 1, 2026

VA-26-00012979

PWS Version Number: ~~1.9~~ 1.10

1.0 BACKGROUND

The mission of the Department of Veterans Affairs (VA) Veterans Health Administration (VHA) is to provide superior healthcare services to Veterans of the United States. As the largest integrated healthcare system in the country, VA is uniquely positioned to develop and provide advanced healthcare capabilities to over 9 million Veterans. One significant challenge facing the VA and its ability to deliver high quality and reliable patient care to our Nation's Veterans is the increase in demand for veteran patients to be seen within the VA healthcare system. In the short window of time allocated for each patient appointment, providers have a multitude of clinical and administrative tasks to be completed. This increases risk of important information being omitted due to rushed interviews and contributes to provider burn out. The myriad of tasks expected of providers beyond caring for patients puts significant cognitive burden and increased strain on them professionally. This strain has the potential to negatively impact patient care. It can also contribute to provider attrition, causing additional impact to Veterans and clinical staff.

One method to reduce the risk of missing vital clinical information that impacts patient care planning and reducing cognitive burden for our providers is the use of ambient scribe technology. Artificial Intelligence (AI) ambient scribes utilize a microphone on a secure device. The ambient AI scribe transcribes patient encounters. It then uses machine learning and natural-language processing to summarize the conversation's clinical content and produce a transcribed note documenting the visit. Such transcribed conversations between patients and providers automatically leverage AI technologies to create notes in the appropriate format (generate clinical documentation) and summarize a patient's visit. Automating these tasks increases accuracy of information, saves the providers time, and reduces their mental strain. Visit notes that include a patient's care plan is a critical component of treatment and care delivery. The software functions as a medical and clinical system, equipment, device, or software (MCSEDS) as defined in VA Directive 6008.

Ambient scribe technology also enables other labor-saving capabilities to include but not limited to: pre and post visit charting to summarize important information prior to visit by either completing the task with AI or integrating with provider pre-charted note, coding support, order capture, after-visit summaries, drafting care plans and other capabilities.

The ambient scribing solution required is unique to the operational environment and specific challenges faced by the Veterans Health Administration (VHA). In January 2024, VHA undertook an AI Technical Sprint challenge to ensure that potential solutions were rigorously tested through a competitive and impartial evaluation process under H.R. 4521-Bioeconomy Research and Development Act Of 2021 [America COMPETES Act of 2022]. The goal of the competition was to identify the top AI solutions identified through the VHA AI Tech Sprint Track 1: Ambient Dictation of Clinical Encounters.

Throughout the Technical Sprint, many solutions demonstrated superior technical maturity and clinical performance. Their development was closely aligned with the urgent needs of the VHA, specifically targeting enhancements in provider burnout and clinical documentation efficiencies. IT professionals and healthcare providers assessed

these solutions for their maturity and practical applicability in real-world clinical settings, ensuring that they met the highest standards for operational readiness.

Moreover, the effectiveness and safety of these solutions were evaluated through a series of blind scoring assessments. Physicians compared the AI-generated outputs against those produced by human clinicians, establishing their accuracy and reliability without bias. Additionally, their usability and potential for seamless integration into the VHA's existing EHR systems were critically assessed to determine their capability to enhance operational continuity and data consistency within the VA health care system. This approach ensured a thorough evaluation of potential Contractors in a manner that fostered broad competition and verified that the selected Contractors met legal, technical, and operational requirements. Evaluations concluded in May 2024.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. "Federal Information Security Modernization Act of 2014"
2. Federal Information Processing Standards (FIPS) Publication 140-3, "Security Requirements for Cryptographic Modules", March 22, 2019
3. FIPS Pub 199. "Standards for Security Categorization of Federal Information and Information Systems," February 2004
4. FIPS Pub 200, "Minimum Security Requirements for Federal Information and Information Systems," March 2006
5. FIPS Pub 201-3, "Personal Identity Verification of Federal Employees and Contractors," January 2022
6. 10 U.S.C. § 2224, "Defense Information Assurance Program", as amended
7. 5 U.S.C. § 552a, as amended, "The Privacy Act of 1974"
8. Public Law 109-461 (P.L. 109-461), Veterans Benefits, Health Care, and Information Technology Act of 2006, as amended, Title IX, Information Security Matters
9. 42 U.S.C. § 2000d "Title VI of the Civil Rights Act of 1964", as amended
10. VA Directive 0710, "Personnel Security and Suitability Program," June 4, 2010, <https://www.va.gov/vapubs/index.cfm>
11. VA Handbook 0710, "Personnel Security and Suitability Program," May 2, 2016, <https://www.va.gov/vapubs/index.cfm>
12. VA Directive 6102, "Internet/Intranet Services," August 5, 2019
13. 36 C.F.R. Part 1194 "Information and Communication Technology Standards and Guidelines," as amended
14. Office of Management and Budget (OMB) Circular A-130, "Managing Federal Information as a Strategic Resource," July 28, 2016
15. 32 C.F.R. Part 199, "Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)", as amended
16. NIST SP 800-66 Rev. 2, "Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide," February 2024
17. 45 C.F.R. Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 C.F.R.

- Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"); as amended
18. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended
 19. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
 20. VA Directive 6500, "VA Cybersecurity Program," February 24, 2021 (see VA NOTICE 24-18, dated September 27, 2024, "Update to VA Directive 6500 Cybersecurity Program", and VA Notice 25-07, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15")
 21. VA Handbook 6500, "Risk Management Framework for VA Information Systems VA Information Security Program," February 24, 2021 (see VA Notice 25-01, dated October 15, 2024, "Update to VA Handbook 6500 Risk Management Framework for VA Information Systems VA Information Security Program", and VA Notice 25-06, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15")
 22. VA Handbook 6500.2, "Management of Breaches Involving Sensitive Personal Information (SPI)," June 30, 2023
 23. VA Handbook 6500.6, "Contract Security," March 12, 2010 (see VA Notice 24-12, dated April 22, 2024, "Update to VA Handbook 6500.6, Contract Security, Appendix C VA Information and Information System Security/Privacy Language For Inclusion Into Contracts, As Appropriate")
 24. VA Handbook 6500.8, "Information System Contingency Planning," March 25, 2025
 25. VA Handbook 6500.10, "Mobile Device Security Policy," February 15, 2018
 26. VA Handbook 6500.11, "VA Firewall Configuration," August 22, 2017
 27. OIT Process Asset Library (PAL), [OIT Process Asset Library](#).
 28. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
 29. VA Directive 6508, "Implementation of Privacy Threshold Analysis and Privacy Impact Assessment," October 15, 2014
 30. VA Directive 6510, "VA Identity, Credential and Access Management," September 3, 2024
 31. VA Handbook 6510, "VA Identity, Credential and Access Management," September 27, 2024
 32. VA Directive and Handbook 6513, "Secure External Connections," October 12, 2017
 33. VA Directive 6300, "Records and Information Management," September 21, 2018
 34. VA Handbook, 6300.1, "Records Management Procedures," March 24, 2010
 35. NIST SP 800-37 Rev 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," December 2018
 36. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," September 23, 2020 (includes updates as of 12/10/2020)
 37. VA Directive 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," October 26, 2015
 38. VA Handbook 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," March 24, 2014

39. OMB Memorandum 05-24, "Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors," August 5, 2005
40. OMB Memorandum M-19-17, "Enabling Mission Delivery Through Improved Identity, Credential, and Access Management," May 21, 2019
41. OMB Memorandum, "Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation," May 23, 2008
42. Federal Identity, Credential, and Access Management (FICAM) Architecture, June 30, 2023 ([FICAM Architecture \(idmanagement.gov\)](https://www.ficam.gov/))
43. NIST SP 800-116 Rev 1, "Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access," June 2018
44. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, "Digital Identity Guidelines," updated March 02, 2020
45. NIST SP 800-157, "Guidelines for Derived PIV Credentials," December 2014
46. VA Memorandum, VAIQ #7100147, "Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12)," April 29, 2011 (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
47. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>))
48. VA Memorandum "Personal Identity Verification (PIV) Logical Access Policy Clarification," July 17, 2019, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
49. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, <https://www.cisa.gov/publication/tic-30-core-guidance-documents>
50. OMB Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative," September 12, 2019
51. OMB Memorandum M-08-23, "Securing the Federal Government's Domain Name System Infrastructure," August 22, 2008
52. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (P.L. 110–140), December 19, 2007
53. Section 104 of the Energy Policy Act of 2005, (P.L. 109–58), August 8, 2005
54. Executive Order 13221, "Energy-Efficient Standby Power Devices," August 2, 2001
55. VA Directive 0057, "VA Environmental Management Program," October 25, 2022
56. Office of Information Security (OIS) VAIQ #7424808 Memorandum, "Remote Access," January 15, 2014, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
57. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
58. "Veteran Focused Integration Process (VIP) Guide 4.0," March 2021, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371>
59. VA Memorandum "Proper Use of Email and Other Messaging Services," January 2, 2018, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
60. "Product Line Management Transformation Playbook" version 3.1, August 2023, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>
61. NIST SP 500-267B Revision 1, "USGv6 Profile," November 2020

62. OMB Memorandum M-21-07, "Completing the Transition to Internet Protocol Version 6 (IPv6)," November 19, 2020
63. Social Security Number (SSN) Fraud Prevention Act of 2017
64. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018
65. C.F.R Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", as amended
66. Executive Order 14028, "Executive Order on Improving the Nation's Cybersecurity," May 12, 2021, <https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2025/01/16/executive-order-on-strengthening-and-promoting-innovation-in-the-nations-cybersecurity/>
67. OMB Memorandum M-22-09, "Moving the U.S. Government Toward Zero Trust Cybersecurity Principles", January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>.
68. NIST SP 800-52 Revision 2, "Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations
69. OMB M-22-18, "Enhancing the Security of the Software Supply Chain through Secure Software Development Practices," September 14, 2022
70. OMB M-23-16, "Update to Memorandum M-22-18," June 9, 2023
71. OMB M-21-31, "Improving the Federal Government's Investigative and Remediation Capabilities Related to Cybersecurity Incidents," August 27, 2021
72. NIST SP 800-88 Revision 1 "Guidelines for Media Sanitization," December 2014
73. CISA Binding Operational Directive (BOD) 19-02: "Vulnerability Remediation Requirements of Internet-Accessible Systems," April 29, 2019, [BOD 19-02: Vulnerability Remediation Requirements for Internet-Accessible Systems | CISA](#)
74. CISA BOD 22-01: "Reducing the Significant Risk of Known Exploited Vulnerabilities," November 3, 2021, [BOD 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities | CISA](#)
75. CISA BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks." Cybersecurity & Infrastructure Security Agency (CISA), [BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks | CISA](#)
76. VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, June 03, 2019
77. VA Memorandum, "VA Security Controls," January 17, 2025, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>
78. General Records Schedule (GRS) 5.2, Transitory and Intermediary Records, June 2023, <https://www.archives.gov/files/records-mgmt/grs/grs05-2.pdf>
79. E.O. 13960, "Promoting the Use of Trustworthy Artificial Intelligence in the Federal Government," December 3, 2020
80. E.O. 14319, "Preventing Woke AI in the Federal Government," July 23, 2025
81. OMB Memorandum [M-25-21](#), "Accelerating Federal Use of AI through Innovation, Governance, and Public Trust," April 3, 2025
82. OMB Memorandum [M-25-22](#), "Driving Efficient Acquisition of Artificial Intelligence in Government," April 3, 2025

83. OMB Memorandum [M-26-04](#), "Increasing Public Trust in Artificial Intelligence (AI) Through Unbiased AI Principles," December 11, 2025

3.0 SCOPE OF WORK

The purpose of this Indefinite Delivery Indefinite Quantity (IDIQ) contract is to provide a Commercial-Off-the-Shelf (COTS), cloud-based, ambient scribe solution to transcribe clinical encounters, generate notes, and other AI advanced functionalities to improve the efficiency of medical care utilizing a Software as a Service (SaaS) delivery model with AI techniques and technologies. This solution shall integrate with VA's EHR systems and workflows so providers can initiate encounter recordings. This mitigates the need for manual entry of patient identifying information and enables automatic insertion of draft notes into EHR.

The Contractor shall not initiate contact with, or conduct demonstrations, interviews, or other engagements at any site actively participating in an implementation effort under this contract if the Contractor has not been awarded a Task Order for that site, or for any other site falling under the scope of this contract, unless expressly authorized in writing by the COR or VA PM. This restriction is intended to preserve the integrity of site activities and prevent unsolicited vendor influence, as well as to preserve the integrity of future task order competitions. Unauthorized engagement may be considered a breach of contract and/or result in future restrictions on competition.

4.0 PERFORMANCE DETAILS

4.1 CONTRACT TYPE

This is an IDIQ Multiple Award Task Order (MATO) contract. Individual Task Orders (TO) shall be issued on a Firm-Fixed-Price basis.

4.2 ORDERING PERIOD

The ordering period for the basic contract shall be 5-years following the date of award.

4.3 HOURS OF WORK

Any work at the Government site shall not take place on Federal holidays or weekends unless directed by the Contracting Officer (CO).

There are 11 Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, five are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

4.4 PLACE OF PERFORMANCE

Products and services ordered under this contract shall be delivered to and installed at VA locations within the continental United States (CONUS) and/or outside the continental United States (OCONUS) as specified in individual Task Orders. Incidental services, such as training, shall be provided at these locations as requested by VA. Work may be performed at Contractor facilities or remote locations other than Contractor facilities with prior concurrence from the Contracting Officer Representative (COR).

4.5 TRAVEL

Travel shall be in accordance with individual TO requirements. Travel details must be provided to and approved in writing by the COR or the Government designee prior to the commencement of travel. All travel shall be in accordance with (IAW) the Federal Travel Regulations (FTR). OCONUS travel may require additional authorization and approvals as specified in the individual TO.

5.0 SPECIFIC TASKS AND DELIVERABLES

The Contractor shall provide and/or acquire the services and products required by individual TOs pursuant to the requirements specified below. The Contractor shall provide an Ambient Scribe solution and all associated licenses, applications and services necessary to meet the requirements defined in this PWS.

5.1 FUNCTIONAL REQUIREMENTS

Individual Task Orders may encompass more than one functional requirement listed below.

5.1.1 AMBIENT SCRIBE

The advanced AI-enabled tools for ambient scribing focus on enhancing clinical documentation across primary care, mental health, and specialty care settings. The solution shall meet the following requirements:

- **Transcription and Note Generation:** Automatically extract transcripts and key details from ambient recordings of patient encounters, creating traceable, high-fidelity medical records to include capabilities to populate diversified note templates.
- **Interoperability and Integration:** Seamlessly integrate with existing VA health system information technologies, particularly the Electronic Health Record (EHR) systems, to ensure smooth operational continuity and data consistency.

- Currently known additional integrations include, but are not limited to, pre-charting, medical coding, order processing, care plans, patient summaries, and medical record interrogation
- Security Compliance: Adhere to stringent VA privacy and security standards for the protection of patient data.
- Advanced Functionalities: Provide continuous improvements to include, but not limited to: record query, recommend diagnoses and referrals, inpatient discharge summaries, nursing patient management, pre-charting capabilities and maintain high performance even in challenging clinical settings.
- Patient Communications: Generate patient-facing summaries (After Visit Summaries and Discharge Summaries) that include, but not limited to: educational materials, reminders, and follow-up recommendations which adhere to clinical documentation compliance standards.

5.1.2 PLATFORM FUNCTIONAL REQUIREMENTS

The ambient dictation system shall run passively on Government equipment or personal equipment managed under VA's Bring Your Own Device program during clinical encounters and generate draft clinical documentation following the encounter in near real-time with a maximum limit of two minutes. The system shall work in a variety of clinical settings, including those with poor wireless signals, poor cellular data, and in a variety of room sizes and setups. Providers shall have the opportunity to edit any AI generated material prior to signing it in the EHR (Vista and CPRS).

5.1.2.1 FedRAMP

The Contractor shall provide a cloud-hosted, Commercial Off-the-Shelf (COTS) ambient dictation SaaS solution, on a Contractor-provided infrastructure that is compliant with the Federal Risk Authorization Management Program (FedRAMP). The solution will be authorized at the Moderate Impact Level in accordance with the Day 1 TO, and as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement. For specific platform functional requirements, the Contractor shall visit the FedRAMP website at www.fedramp.gov. For questions about FedRAMP, the Contractor shall email info@fedramp.gov.

5.1.2.2 AUTHORITY TO OPERATE

The Contractor shall obtain an agency issued ATO for their provided solution from the VA. Joint Authorization Board (JAB) ATO is not acceptable as a substitute. An approved ATO shall be required for the entire PoP.

The Contractor shall submit for an agency ATO upon Task Order award. Specific requirements will be included in the Task Order. Failure to obtain an agency ATO shall be considered a breach of contract.

5.1.2.3 SaaS SOLUTION

The Contractor shall provide a SaaS solution that shall include a clinician facing web-based application and mobile application compatible with Microsoft (MS) Windows,

Apple iOS, and Android operating system (OS). The Contractor provided mobile application shall only be available on the VA App Store.

5.1.3 AMBIENT DICTATION IMPLEMENTATION

The Contractor shall implement the ambient dictation capability throughout identified Veterans Integrated Service Networks (VISN). It is expected that EHR system integration will occur during the time the contractor is awaiting an ATO. The Contractor shall provide a secure URL to enable access, set up, and configuring of the platform at each site. The Contractor shall provide operational training, support and guidance to medical center personnel on the use of the software. The solutions shall maintain and make available any transcripts or recordings for 30 days to maintain compliance with federal record schedules for intermediary documents. All intermediary documents and recordings will be deleted immediately upon day 31. Individual records may be flagged for retention longer than 30 days should a legal requirement exist such as a FOIA. Request for retention shall be made by the COR and be available until the COR requests deletion.

5.1.4 EHR INTEGRATION

The solution shall be integrated with the EHR and workflows such that providers can conduct pre-charting, initiate encounter recording without manual entry of patient identifying information, and draft notes can be automatically inserted into the EHR without copy and paste manual effort. The integration must comply with VA authorization and authentication standards, and integrate with APIs exposed by VA. The Contractor shall collaborate with VA technical teams to develop and test the integration workflows.

Finally, the Contractor shall support VA efforts to measure the solution's impact and collaborate with VA to identify additional integrations needed for scalable use beyond the initial capabilities.

5.1.5 TRAINING

The Contractor shall:

1. Provide remote (virtual) training for VA clinicians who have been provided licenses. Training dates shall be coordinated with VA PM and individual site points of contact (POCs). Any in person or localized training shall be recorded for future reference. All training recordings captured during VA training sessions shall be provided to COR or their designee and considered VA property. The Training shall include an overview of the platform and detailed walkthrough of the capabilities.
2. Provide training materials to VA five (5) days prior to any training session. The Training Materials shall provide role-based training information and a user guide to address how to utilize the ambient dictation platform. Material shall include but not be limited to a detailed user manual and quick reference guide provided in digital formats.

5.1.6 TECHNICAL SUPPORT

Provide technical support (online and via phone) during normal duty hours: Monday through Friday, 7:00 a.m.-5:30 p.m. local time in accordance with the implementing facility's respective time zone. Technical support shall troubleshoot and resolve technical, functional, and access issues. **The Contractor shall provide a centralized support capability to address issues across all VISNs.** The Contractor shall propose call center KPIs and benchmarks in proposal but shall include at a minimum Average Speed to Answer of less than 1 minute, Abandonment Rate less than 5%, First Call Resolution Rate, and Customer Satisfaction or Net Promoter Score.

5.1.7 ASSESSMENT, AUTHORIZATION, AND CONTINUOUS MONITORING

The Contractor shall adhere to all applicable FIPS, NIST, FISMA and FedRAMP standards and requirements related to assessment, authorization, and continuous monitoring.

The Contractor shall provide and maintain an ATO in accordance with the guidance provided in VA Directive and Handbook 6500.

5.1.8 SITE CONFIGURATIONS

The solution shall be configured to work within VA medical facilities, designated by their station numbers and associated clinical note templates, as identified in each individual TO.

5.1.9 ADDITIONAL CAPABILITIES

VA's requirements are expected to evolve over the course of the IDIQ. To support evolving Government requirements while minimizing risk to both the Contractor and VA, the parties shall engage in ad hoc future-capability planning cycles discussing capabilities on the vendor's roadmap relative to VA mission needs. Future requirements may include, but are not limited to, additional data connections, software, enhanced AI-enabled functionality, and tools.

The Contractor shall meet with VA once a year to provide visibility into the Contractor's roadmap of future capabilities. The Contractor's roadmap shall detail capabilities that the Contractor is anticipating to develop as part of its generally available (GA) product offerings over one-, two-, and three-year time periods.

The Contractor shall include VA in all user groups and other planning activities that other major clients participate in and that are used to inform the prioritization of the Contractor's development backlog. VA may provide input regarding capability prioritization; however, inclusion in planning activities does not constitute a commitment by the Government to acquire any specific capability.

The Contractor shall provide VA the right to acquire additional modules or capabilities developed during the PoP of this contract, subject to availability, scope, and pricing established in accordance with the IDIQ.

The Contractor shall coordinate with VA staff to thoroughly test all additional capabilities prior to deployment in a production environment. Testing shall be conducted by VA staff in real time at the designated VA testing facility.

Upon completion of each additional capability test, VA will review the outputs and certify the additional capability. The Contractor shall not deploy any additional capabilities into production until VA provides the certification statement for the specific additional capability.

The additional capabilities shall comply with applicable VA security, privacy, policy, or other VA requirements which shall be identified at the time of deployment and specified in the applicable Task Order.

5.1.10 SPECIALTY SERVICE TEMPLATES

The Contractor shall support the expansion of the Ambient Scribe Solution into specialty care services. The Contractor shall provide the algorithm training for specialty care services in the format requested by the VA. VA will provide supplementary note templates and access to subject matter experts to ensure the ability to capture essential information for patient encounters. Specific tasks and deliverables will be specified in the TO.

5.1.11 INTEGRATION OF ADDITIONAL AI ENABLED CAPABILITIES

The Government reserves the right to incorporate additional AI-enabled capabilities that support clinical documentation, workflow optimization, and/or clinical decision support, provided such capabilities fall within the general scope of this contract.

As new capabilities are developed and used by the commercial industry or the Government, the VA and/or Contractor may identify these technologies, and propose necessary additions, modifications, upgrades, enhancements, and improvements.

The Contractor shall maintain, and provide upon request, current documentation of publicly available pricing for relevant capabilities. The Government reserves the right to validate proposed pricing through independent market research or third-party verification. This pricing structure ensures that any future expansion of capabilities remains within the scope of the original competition and is consistent with applicable acquisition regulations.

5.1.12 Licensing

The Contractor shall provide Ambient Scribe licenses as specified in each TO. The Contractor shall follow the activation and deactivation procedures in Section 5.1.12.1 and 5.1.12.2 of this PWS, unless otherwise specified in the TO.

5.1.12.1 Activation

The Contractor shall provide and activate licenses and associated accounts upon the COR's, or other VA official as specified in the TO, request. The Contractor shall complete activation requests within three business days. The Contractor shall notify the

COR, or specified VA official, when the licenses and associated accounts are ready for user access. The Contractor's notification shall include, at minimum, the number of licenses activated, activation date, and any necessary user access details.

5.1.12.2 Deactivation

The Ambient Scribe Solution shall have the capability to automatically identify and flag licenses that have registered no usage activity for a period of 30 consecutive days. The Solution shall generate an electronic notification listing these unused licenses and transmit it to the IDIQ COR and TO COR, or other VA official, as specified in the TO. The electronic notification shall include the affected user accounts and the associated licenses.

The Contractor shall accommodate account deactivation requests from the COR, or other VA official, as specified in the TO. Upon receipt of request, the Contractor shall complete the deactivation activities within three business days, or on a later date specified by the COR, or other VA official, provided the request is received with three business days lead time.

5.2 TRANSITION AND ORIENTATION SUPPORT

The Contractor shall perform transition and orientation services (e.g. develop a Phase-In/Phase-Out Transition Plan) to ensure continuity of services as specified in the individual TO. Transition and orientation support may include transitioning support services to Government or Contractor personnel.

5.3 CONTRACT MANAGEMENT

The Contractor shall provide contract and TO level management. The Contractor shall work closely with the Government to manage contractual and programmatic issues that arise during performance of the contract. The Contractor shall be responsible for the execution of all contract tasks to include, but not be limited to: program reviews; kickoff meetings; status updates; various reporting requirements; and day-to-day concerns. A national Government CO and COR will address enterprise-wide issues. Ordering VA facilities will designate a facility COR/POC that the Contractor shall work with to coordinate facility orders.

5.3.1 TASK ORDER KICKOFF MEETINGS

If required by the ordering facility, the Contractor shall participate in a TO level kickoff meeting and brief the Government on how it intends to meet the requirements of the TO. The kickoff meeting shall be held virtually. Specific requirements will be detailed in the individual Task Orders.

5.3.2 PROJECT MANAGEMENT

Contractor shall not perform inherently Governmental functions including: decision-making, supervision of Government employees, supervision of other Contractors on other contracts, and activities that create the appearance of performing such functions.

Contractor shall deliver all written artifacts using straightforward language. Technical and mathematical terms shall only be used when accompanied by a glossary. Deliverables shall be accepted based, in part, on satisfaction of Section 508 of the Rehabilitation Act of 1973. VA reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

Contractor shall submit final written deliverables in Microsoft Word, PowerPoint, or Excel format. Contractor shall provide files converted to Adobe PDF format upon request by the COR or Program Manager (PM).

The Government will review each deliverable and provide feedback/comments. After Government review, the Contractor shall have five (5) business days to incorporate feedback/comments and make appropriate revisions. The Contractor shall provide the revised version of each deliverable to the Contracting Officer Representative (COR). The COR will review and determine final acceptance by the Government.

5.3.3 REPORTING REQUIREMENTS

5.3.3.1 MONTHLY REPORTS

The Contractor shall furnish to VA, for the purposes of evaluation, oversight, and continuous improvement, access to data generated by or through the Ambient Scribe AI solution. The Contractor shall make the data available to VA either through reporting dashboards or delivered via secure file transfer as requested by the COR or their designee.

Data provided shall include, at a minimum, the following categories of data. The examples listed are illustrative and not intended to be exhaustive:

1. Monthly License Usage Reports – including number of activated and deactivated licenses throughout the VA.
2. Encounter Metadata – such as timestamps, user and license identifiers, site, specialty, device type, and software version.
3. Utilization Metrics – including per-license and per-encounter usage data.
4. Transcripts – textual transcripts with speaker attribution and timing information.
5. Draft and Final Notes – including draft content, delivery status, and edit trace from draft to final.
6. AI-Generated Recommendations and Clinical Decision Support – including suggested codes, clinical reminders, alerts, and other structured outputs intended to support documentation or care.
7. End User Feedback & Support Requests – including structured and unstructured feedback submitted by users.

The Contractor shall retain all data associated with the encounters in accordance with General Records Schedules 5.2, Transitory and Intermediary Records.

If a Contractor Project Management Plan (CPMP) is required in an individual TO, the Contractor shall monitor performance against the Task Order CPMP and report all deviations. It is expected that the Contractor shall keep in communication with the CO

and COR so that issues that arise are transparent to both parties to prevent escalation of outstanding issues.

Deliverable:

- A. Monthly Report

5.3.3.2 QUARTERLY SUMMARY REPORT

The Contractor shall provide, via email, the national COR and CO with Quarterly Summary Reports in Microsoft Office format. The Summary Reports shall cover all Task Orders issued and completed during the reporting period and Task Orders planned, to the extent known, for the subsequent reporting period. The report shall track the cumulative contract ceiling. The Summary Report shall identify current implementation status, any problems that have arisen, and a description of how the problems were resolved. If problems have not been completely resolved, the Contractor shall provide an explanation including its plan and timeframe for resolving the issue. It is expected that the Contractor will maintain timely communication with VA so that the issues that arise are transparent to both parties to prevent escalation of outstanding issues. The Quarterly Summary Reports shall include:

1. Contract/Order Number
2. Date of Award
3. Facility COR/POC Name, Telephone Number, Location
4. Integrated Funds Distribution Control Point Activity Accounting & Procurement (IFCAP) Purchase Order Number
5. Total Dollars Obligated
6. Software Version Number, License Type, and Term
7. Technical Support Toll Free Telephone Number and Website

Deliverable:

- A. Quarterly Summary Report

5.3.4 PRE-AWARD TASK ORDER PROCEDURES

5.3.4.1 TASK EXECUTION PLAN (TEP)

Fair opportunity requirements shall be IAW applicable statutes, regulations, and case law. RTEP(s) will be issued to eligible IDIQ contract holders to compete Task Orders under this contract. The Government anticipates issuing RTEPs to select one Contractor per VISN; however, the Government reserves the right to structure competitions as appropriate to meet program requirements. The Government's RTEP does NOT constitute an authorization to start work.

Within seven (7) work days of receipt of the RTEP, or unless otherwise specified in the RTEP, the Contractor shall submit one TEP IAW the format provided below unless otherwise specified by the CO. The following information shall be provided and submitted to the CO:

A. In addition to the information requested in the RTEP, the following shall be addressed in every TEP:

1. Proposal Summary Volume including:
 - a. Task number.
 - b. Date submitted.
 - c. Contractor's name, Unique Entity Identifier (UEI) and Commercial and Government Entity (CAGE) Code.
 - d. Contractor task leader contact information for questions.
 - e. Subcontractor(s) shall be identified by name, UEI and CAGE Code at all tiers (as applicable).
 - f. Proposed start and finish dates.
 - g. Proposed total price.
 - h. Offerors are hereby advised that any Offeror-imposed terms and conditions which deviate from the Government's material terms and conditions established by the RTEP, may render the Offeror's proposal Unacceptable, and thus ineligible for award.
 - i. Duration for which proposal is valid (minimum 90 days)
 - j. VAAR 852.209-70 is in effect for all RTEPs issued and the contractor should provide a statement IAW VAAR 852.209-70(b), when applicable
 - k. Acknowledgement of Amendments.

B. The following shall be addressed:

A price proposal volume shall be submitted in Microsoft Excel Spreadsheet format and shall contain the following:

1. The first tab shall be a summary to include a top level rollup of the total dollars and percentages by labor, materials, travel, ODCs, and total Task Order price.
2. The Contractor shall submit, as a separate tab, a completed Section B price schedule inclusive of all priced line items for base period and any options.
3. Offerors are hereby advised that any Pricing Assumptions which deviate from the Government's requirements or material terms and conditions established by the RTEP, may render the Offeror's proposal Unacceptable, and thus ineligible for award.
4. "Information Other than Cost or Pricing Data" may be required where there is not "adequate price competition" as defined in FAR 15.403-1(b).

C. The following pertains to the preparation and submission of all TEPs:

1. Contractors are NOT to submit past performance as a part of their TEP, unless specified in the RTEP.
2. TEP Format
 - a. Proposal Summary Volume
 - i Microsoft (MS) Word Office 365, only. The Offeror shall certify that its entire proposal, including all volumes, has been submitted in the MS Office 365 Program.
 - b. Technical Volume
 - i The Technical Volume shall be submitted in MS Word, Office 365, only. Compliance with the submission instructions shall be measured using the font size, scale, spacing and margin indicators in MS Word, Office 365.

- ii No marketing materials; information relevant to the requirement only
- c. Price Volume
 - i The Price Evaluation Spreadsheet shall be submitted in MS Excel Office 365, only.
- 3. Page Limitations. When page limitations are specified in the RTEP, the following format shall apply:

The Summary and Technical Volumes shall be submitted as a MS Word, Office 365 file only. Price Volume shall be submitted in Microsoft Excel. Page size shall be no greater than 8 1/2" x 11". The top, bottom, left and right margins shall be a minimum of one inch each. Font size shall be no smaller than 12-point. Times New Roman fonts are required. Characters shall be set at no less than normal spacing and 100% scale. Tables and Illustrations are not subject to the font and spacing requirements. All proposal pages, including those containing Tables or Illustrations shall comply with the margin requirements. Tables and Illustrations shall be legible at 100% zoom. If a Table or Illustration is illegible at 100% zoom, then the entire Table or Illustration will be deemed to be in violation and will not be evaluated. Line spacing shall be set at no less than single space. Page numbers, company logos, and headers and footers may be within the page margins ONLY, and are not bound by the 12-point font requirement. Footnotes to text shall not be used. If the Offeror submits annexes, documentation, attachments or the like, not specifically required by this solicitation, such will count against the Offeror's page limitations unless otherwise indicated in the specific Volume instructions. Pages in violation of these instructions, either by exceeding the margin, font or spacing restrictions or by exceeding the total page limit for a particular volume, will not be evaluated. Pages not evaluated due to violation of the margin, font or spacing restrictions will not count against the page limitations. The page count will be determined by counting the pages in the order they come up in the print layout view. The Cover Page and Table of Contents, and/or a glossary of abbreviations or acronyms will not be included in the page count however any additional matrices, appendices, etc. will count against page limitation. Cover letters shall not be included in the Technical Volume.

5.3.4.2 TEP EVALUATION

To the greatest extent possible, VA shall evaluate TEP submittals in an expedited manner. Questions and clarifications may be required which can prolong the evaluation period. When requested by the CO, the Contractor shall provide a revised TEP to address changes. All TEPs shall be subject to evaluation by a team of Government personnel.

5.3.4.3 ISSUANCE OF TASK ORDERS

Upon Government approval of the TEP and designation of an appropriate fund cite, the CO shall issue a Task Order to the Contractor. Contractor work shall commence only after issuance of the Task Order by the CO. The Government shall provide notification of Task Order award to both the successful and unsuccessful Offerors.

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.1.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

6.1.3 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using [VA Enterprise Architecture \(EA\)](#), and VA Identity and Access Management (IAM) approved [Enterprise Technology Guidelines \(ETG\)](#). The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in Executive Order 14028, VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, CISA Binding Operational Directive 23-01, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-3, VA Handbook 6500, and VA IAM enterprise requirements for direct, assertion based authentication, and/or trust based

authentication, as determined by the ETGs. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office of Management and Budget (OMB) Memoranda [M-05-24](#), [M-19-17](#), [M-22-09](#), and NIST Federal Information Processing Standard (FIPS) 201-3. Contractor delivered applications and systems shall be on the FIPS 201 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

1. Automated provisioning and are able to use enterprise provisioning service.
2. Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
3. The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
4. Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
5. Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
6. Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
7. Two-factor authentication (2FA) through an applicable Technology Guideline as outlined in VA ETG.
8. A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-3 guidelines.
9. Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
10. Role Based Access Control.
11. Auditing and reporting capabilities.
12. Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

6.1.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines

technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 “USGv6 Profile” (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 “Guidelines for the Secure Deployment of IPv6” (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.1.5 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative” (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 “Secure External Connections”, and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>).

6.1.6 STANDARD COMPUTER CONFIGURATION

The Contractor IT end user solution that is developed for use on standard VA computers shall be compatible with and be supported on the standard VA operating system, Windows 10 (64bit) and Windows 11, Edge (Chromium based), and 365 Apps for enterprise. Applications delivered to VA and intended to be deployed to Windows 10 and or Windows 11 workstations shall be delivered as a signed .msi package with switches for silent and unattended installation and updates shall be delivered in signed .msp file formats for easy deployment using Microsoft Endpoint Configuration Manager (CM) VA’s current desktop application deployment tool. Signing of the software code shall be through a vendor provided certificate that is trusted by VA using a code signing authority such as Verizon/Cybertrust or Symantec/VeriSign. The Contractor shall also ensure and certify that their solution functions as expected when used from a standard VA computer, with non-admin, standard user rights that have been configured using the Defense Information Systems Agency (DISA) Secure Technical Implementation Guide (STIG) specific to the particular client operating system being used.

6.1.7 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA efforts IAW the Veteran-Focused Integration Process (VIP) Guide and Product Line Management (PLM) Playbook. The major focus of VIP is on Enterprise Oversight, Governance, reporting, and establishing practices that focus on outcomes and continuously delivering sustainable IT capabilities to benefit the

Veteran. PLM is a framework that focuses on delivering functional products that provide the highest priority work to customers while delivering simplified, reliable, and practical solutions to the business, medical staff, and our Veterans. The VIP Guide is a companion guide to the PLM Transformation Playbook and can be found at: <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371> and the PLM Transformation Playbook can be found at <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>. VIP and PLM are the authoritative processes that IT projects must follow to ensure development and delivery of IT products.

The VIP Guide provides guidance for transitioning from project-centric to product-centric delivery. The VIP guide applies to all OIT Office of Management and Budget (OMB) reportable products that are required to collect and report costs, schedules, risks, and other valuable information in VA PARS (whether products are procured or developed by VA) and any VA Information Technology project effort in Software Product Management (SPM) and Infrastructure Operations (IO), or their successors, that touch the VA network regardless of IT organizational alignment (whether it spends government funding from VA's Congressional IT Appropriation or any other appropriation).

The PLM Transformation Playbook details how OIT leadership expects Product Lines (PLs) to implement PLM, DevOps, and Lean-Agile principles, methods, practices, and techniques through levels of maturity. The PLM Transformation Playbook applies to all Information Technology (IT) products aligned to PLs in the Software Product Management, Infrastructure Operations and Product Engineering organizations within the OIT organization.

Others outside the referenced groups or organizations may use the VIP Guide and PLM Transformation Playbook for situational awareness as needed.

6.1.8 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The PAL includes a spectrum of OIT functions and activities, such as project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. OIT utilizes PAL processes to ensure compliance with policies and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at [process CONB_ext.docx \(live.com\)](https://www.va.gov/process). The main PAL can be accessed at www.va.gov/process.

6.1.9 AUTHORITATIVE DATA SOURCES

The VA Enterprise Architecture Repository (VEAR) is one component within the overall EA that establishes the common framework for data taxonomy for describing the data architecture used to develop, operate, and maintain enterprise applications. The Contractor shall comply with the department's Authoritative Data Source (ADS) requirement that VA systems, services, and processes throughout the enterprise shall

access VA data solely through official VA ADSs where applicable, see below. The Information Classes which compose each ADS are located in the VEAR, in the Data & Information domain. The Contractor shall ensure that all delivered applications and system solutions support:

1. Interfacing with VA's Master Person Index (MPI) (formerly the Master Veteran Index (MVI)) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
2. Interfacing with Capital Asset Inventory (CAI) to conduct real property record management actions, if the solution relies on real property records data. CAI is the authoritative source for VA real property record management data.
3. Interfacing with electronic Contract Management System (eCMS) for access to contract, contract line item, purchase requisition, offering vendor, and solicitation information above the micro-purchase threshold, if the solution relies on procurement data. ECMS is the authoritative source for VA procurement actions data.
4. Interfacing with HRSmart Human Resources Information System to conduct personnel action processing, on-boarding, benefits management, and compensation management, if the solution relies on personnel data. HRSmart is the authoritative source for VA personnel information data.
5. Interfacing with VA Profile to access personal contact information, if the solution relies on VA Veteran personal contact information data. VA Profile is the authoritative source for VA Veteran Personal Contact Data.
6. Interfacing with VA/Department of Defense (DoD) Identity Repository (VADIR) for determining eligibility for VA benefits under Title 38, if the solution relies on qualifying active duty military service data. VADIR is the authoritative source for qualifying active duty military service in VA.
7. Interfacing with VA Systems Inventory (VASI) to access VA systems information, if the solution relies on VA system information. VASI is the authoritative source for VA Information Technology systems.
8. Interfacing with Enterprise Mission Assurance Support Service (eMASS) to access the Authority to Operate (ATO) status of all VA Information Systems. eMASS contains the official Authority to Operate (ATO) status of all VA Information Systems.

6.1.10 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the ICN in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA MPI for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain

information VA requires from an information system that is not under the jurisdiction of VA.

6.1.11 SOURCE CODE HARMONIZATION AND REUSE IN INFORMATION TECHNOLOGY (SHARE IT) ACT

The Contractor shall comply with the Source Code Harmonization and Reuse in Information Technology (SHARE IT) Act, P.L. 118-187, when developing and delivering custom code first produced for the VA in the performance of this Contract/Order. The Contractor shall deliver to the Government all data first produced under this Contract/Order with unlimited rights as defined by FAR 52.227-14, to include without limitation, all custom-developed code and other key technical components of the code (including documentation, data models, schemas, metadata, architecture designs, configuration scripts, and artifacts required to develop, build, test, and deploy the code). Custom-developed code includes source code, or segregable portions of source code and all documentation created in support thereof to include source code written for a software project, product, module, plugin, script, middleware, or application programming interface. The Custom-developed Code Package required under this section shall be delivered as required in accordance with the initial (Day One) Task Order.

Deliverable:

- A. Custom-developed Code Package

6.2 SECURITY AND PRIVACY REQUIREMENTS

It has been determined that protected health information may be disclosed or accessed and a signed Business Associate Agreement (BAA) shall be required. The Contractor shall adhere to the requirements set forth within the BAA, referenced in Section D of the contract, and shall comply with VA Directive 6066.

6.2.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Security and Suitability Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PWS are:

Position Sensitivity and Background Investigation Requirements by Task

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.1	☒	☐	☐
5.2	☒	☐	☐
5.3	☒	☐	☐

The Tasks identified above and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required

Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

6.2.2 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- a. The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language. Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 (or its successor) are to encrypt the file, use a secure fax, or use a traceable mail service. (Note that by September 22, 2026, all FIPS 140-2 certificate validations will be placed on the Historical List. See FIPS Transition Effort Timeline for more details: <https://csrc.nist.gov/projects/fips-140-3-transition-effort#schedule>)
- b. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Security and Investigations Center (SIC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.
- c. The Contractor shall ensure the following required forms are submitted to the COR within 5 days after contract award:
 - 1) Optional Form 306
 - 2) Self-Certification of Continuous Service
 - 3) VA Form 0710
 - 4) Completed SIC Fingerprint Request Form

The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing the Office of Personnel Management's (OPM) Electronic Questionnaire for Investigations Processing (e-QIP) after receiving an email notification from the SIC.

The Contractor employee shall certify and release the e-QIP document, print, and sign the signature pages, and send them encrypted to the COR for

electronic submission to the SIC. These documents shall be submitted to the COR within 3 business days of receipt of the e-QIP notification email. (Note: OPM is moving towards a “click to sign” process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via e-QIP).

- d. The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this contract, the Contractor shall be responsible for all resources necessary to remedy the incident.
- e. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section 4), signed “Contractor Rules of Behavior”, and with a valid, operational Personal Identity Verification (PIV) credential for PIV-only logical access to VA’s network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by OPM. However, the Contractor will be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of OPM.
- f. The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.

Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.

PIV Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

- A. Contractor Staff Roster

6.2.3 PHYSICAL SECURITY AND SAFETY REQUIREMENTS

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for people violating the law.

- a. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
- b. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in

the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.

- c. Smoking is prohibited inside/outside any building other than the designated smoking areas.
- d. Possession of weapons is prohibited.

The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or Contractor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

6.3 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include: Microsoft 365 suite, MS Word, MS Excel, MS PowerPoint, MS Project, MS Access, MS Visio, AutoCAD, and Adobe Postscript Data Format (PDF).

6.4 PERFORMANCE METRICS

The table below defines the Performance Standards and Acceptable Levels of Performance associated with this effort.

Performance Objective	Performance Standard	Acceptable Levels of Performance
A. Technical / Quality of Product or Service	1. Demonstrates understanding of requirements 2. Efficient and effective in meeting requirements 3. Meets technical needs and mission requirements 4. Provides quality services/products 5. Incorporates "ease of use" Human Centered Design principles in any software developed. 6. KPI for Support	Satisfactory or higher

B. Project Milestones and Schedule	1. Established milestones and project dates are met 2. Products completed, reviewed, delivered in accordance with the established schedule 3. Notifies customer in advance of potential problems	Satisfactory or higher
C. Cost & Staffing	1. Currency of expertise and staffing levels appropriate to perform tasks required 2. Personnel possess necessary knowledge, skills, and abilities to perform tasks	Satisfactory or higher
D. Management	1. Integration and coordination of all activities to execute effort	Satisfactory or higher

The COR will utilize a Quality Assurance Surveillance Plan (QASP) throughout the life of the contract to ensure that the Contractor is performing the services required by this PWS in an acceptable level of performance. The Government reserves the right to alter or change the surveillance methods in the QASP at its own discretion.

6.5 FACILITY/RESOURCE PROVISIONS

The Government will provide office space, telephone service and system access when authorized contract staff work at a Government location as required in order to accomplish the Tasks associated with this PWS. All procedural guides, reference materials, and program documentation for the project and other Government applications will also be provided on an as-needed basis.

The Contractor shall request other Government documentation deemed pertinent to the work accomplishment directly from the Government officials with whom the Contractor has contact. The Contractor shall consider the COR as the final source for needed Government documentation when the Contractor fails to secure the documents by other means. The Contractor is expected to use common knowledge and resourcefulness in securing all other reference materials, standard industry publications, and related materials that are pertinent to the work.

VA may provide remote access to VA specific systems/network in accordance with VA Handbook 6500, which requires the use of a VA approved method to connect external equipment/systems to VA's network. Citrix Access Gateway (CAG) and now the Azure Virtual Desktop (AVD) (as VA is currently transitioning from CAG to the AVD), are the current and only VA approved methods for remote access users when using or manipulating VA information for official VA Business. VA permits CAG remote access through approved Personally Owned Equipment (POE) and Other Equipment (OE) provided the equipment meets all applicable 6500 Handbook requirements for POE/OE. All of the security controls required for Government furnished equipment (GFE) must be

utilized in approved POE or OE. The Contractor shall provide proof to the COR for review and approval that their POE or OE meets the VA Handbook 6500 requirements and VA Handbook 6500.6 Appendix C, herein incorporated as Addendum B, before use. CAG authorized users shall not be permitted to copy, print, or save any VA information accessed via CAG at any time. VA prohibits remote access to VA's network from non-North Atlantic Treaty Organization (NATO) countries. The exception to this are countries where VA has approved operations established (e.g. Philippines and South Korea). Exceptions are determined by the COR in coordination with the Information System Security Officer (ISSO) and Privacy Officer (PO).

This remote access may provide access to VA specific software such as Veterans Health Information System and Technology Architecture (VistA), ClearQuest, PAL, Primavera, and Remedy, including appropriate seat management and user licenses, depending upon the level of access granted. The Contractor shall utilize government-provided software development and test accounts, documents, and requirements repositories, etc. as required for the development, storage, maintenance, and delivery of products within the scope of this effort. All VA sensitive information shall be protected at all times in accordance with VA Handbook 6500, local security field office System Security Plans (SSP's) and Authority to Operate (ATO)'s for all systems/LAN's accessed while performing the tasks detailed in this PWS. The Contractor shall ensure all work is performed in countries deemed not to pose a significant security risk. For detailed Security and Privacy Requirements (additional requirements of the contract consolidated into an addendum for easy reference) refer to ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED and ADDENDUM B - VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE.

6.6 TRUSTWORTHY ARTIFICIAL INTELLIGENCE

For purposes of this clause, AI is defined as set forth by the VA and Section 238(g) of the National Defense Authorization Act for Fiscal Year 2019 to include:

1. Any artificial system that performs tasks under varying and unpredictable circumstances without significant human oversight, or that can learn from experience and improve performance when exposed to data sets.
2. An artificial system developed in computer software, physical hardware, or other context that solves tasks requiring human-like perception, cognition, planning, learning, communication, or physical action.
3. An artificial system designed to think or act like a human, including cognitive architectures and neural networks.
4. A set of techniques, including machine learning (ML), that is designed to approximate a cognitive task.
5. An artificial system designed to act rationally, including an intelligent software agent or embodied robot that achieves goals using perception, planning, reasoning, learning, communicating, decision making, and acting.

The Contract shall provide a list of all AI it will be using as part of contract performance for VA approval and inclusion in the subject contract. This includes, but shall not be limited to, the AI which will be provided as part of its solution for the VA's AI requirement as outlined in the corresponding PWS (if applicable), as well as any other

recommended and/or intended AI for use during contract performance. The list of recommended AI shall be provided directly to the COR at least annually but also at the following times: upon proposal submission, contract award, and the COR's request. AI shall not be used in performance of the contract without the written approval and authorization of the CO. The Contractor shall also report all AI intended for use in contract performance to VA's Digital Health Office DHO. The Contractor shall actively engage in AI discovery, assessment, and compliance activities undertaken by VA. The Contractor shall report all appropriate use cases to VA CAIO through any required inventory processes.

Once the Contractor has obtained CO authorization to use specific AI in contract performance, the Contractor shall provide the COR a signed Statement of Attestation prior to AI implementation as part of the Contractor's proposal submission. The Statement of Attestation shall include, but is not limited to, a description of all controls, processes, technologies, and mechanisms utilized to meet the applicable requirements for the use of AI as set forth in section 6.7. The Statement of Attestation shall also certify that the Contractor owns or possesses all legally required rights, copyright, and licenses to use the specified AI. The Statement of Attestation shall clearly state that the use of the AI by VA personnel in performance of the contract:

1. Does not and will not infringe upon any intellectual property rights of any kind.
2. Does not violate any intellectual property rights of any kind.
3. Does not violate any other third-party rights of any kind.

The Statement of Attestation shall also affirm that there have not been any persisting or existing material errors, defects, failures, or interruptions in AI performance of its intended purpose. Additionally, the Statement of Attestation shall include the Contractor's endorsement that the AI has materially performed in accordance with its specifications and intended purpose. Lastly, the Statement of Attestation shall be updated and resubmitted annually. The Statement of Attestation shall be deemed separate from, and in addition to, the Contractor's reporting requirements relative to the use of AI. The Statement of Attestation is a material term of the contract; accordingly, failure to provide the Statement of Attestation to include all requirements, may be deemed a breach of contract and thus, cause for termination.

The Contractor (or Subcontractor at any tier, including affiliates) shall not sell, monetize, or otherwise release or misuse any VA data to include any models, training data, testing data, patterns, documentation, implementation artifacts, runtime artifacts, or any other digital artifacts, partially or as a whole, derived from AI or machine learning (ML) without the express written consent and approval from the CO.

VA data shall remain the sole and exclusive property of the Agency. The Contractor is provided limited access to use VA data solely for performing its obligations under the Contract. The contractor shall: (a) keep and maintain VA data in strict confidence and as further described in this Contract and applicable law to avoid unauthorized access, use, disclosure, or loss; (b) not use, sell, rent, transfer, distribute, or otherwise disclose or make available VA data for Contractor's own purposes or for the benefit of anyone other than Agency without Agency's prior written consent; and (c) not store, use, and transmit Agency data outside of the United States.

The Contractor is prohibited from using non-public VA data and outputted results to further train publicly or commercially available AI algorithms, consistent with applicable law, except with the express written authorization from the Agency specifying the Agency data that may be used along with the acceptable scope of such usage.

The Contractor may allow VA to fine-tune or conduct other forms of model customization ("Fine-Tuning Services" and any such resulting model, a "Fine-Tuned Model"), including using data provided by VA ("Fine-Tuning Materials"). Fine-Tuning Services use the Fine-Tuning Materials for the purpose of generating or validating Fine-Tuned Models. Fine-Tuning Materials are VA Data. VA's use of the Fine-Tuning Services does not constitute a violation of the prohibition on training in the Agreement; provided that the training conducted is solely for VA's use of the Fine-Tuning Services.

The Contractor shall indemnify VA and its officers, employees, and agents against liability, including costs, for actual or alleged direct or contributory infringement of, or inducement to infringe, any United States or foreign patent, trademark, or copyright, arising out of VA use of any AI products and/or services under the contract.

The Contractor shall maintain commercially reasonable insurance coverage for claims or losses pertaining to the AI products or services being used in performance of the contract.

The Contractor shall maintain commercially reasonable and industry standard conforming security safeguards and controls, including proper access controls for the AI. The Contractor agrees the VA Contracting Officer has the unilateral right to require deactivation of any AI for any reason without notice.

Any development and/or creation of AI, to include AI derivatives and/or data as a result of the performance of this contract is subject to all applicable Intellectual Property and data rights clauses under the Federal Acquisition Regulation (FAR), including FAR 52.227-14. The Contractor retains ownership of all AI technologies and methodologies developed without the use of VA resources and data assets.

The Contractor, in collaboration with VA, must evaluate the output of any AI tool for accuracy prior to using the output in VA efforts. The Contractor shall deliver the services, technical data, configurations, models, weights, documentation or other information, including source code, developed during contract performance. All data, including models, weights, algorithms, and outputs generated using either Government-furnished data or data first developed under this contract shall be the property of the Government. Additionally, the Contractor shall also deliver any data to include models, model weights and custom-developed code with AI methodologies in accordance with the SHARE IT Act (see Section 6.1.11) The Government will receive Unlimited Rights in intellectual property first produced and delivered in the performance of this contract in accordance with FAR 52.227-14, Rights In Data-General (DEC 2007). This includes all rights to source code, models, weights, and any and all documentation created during performance of this task order in support thereof. VA shall also retain unlimited rights to any improvements to that data, including the continued design, development, testing,

and operation of AI systems and/or systems utilizing AI. License rights in any Commercial Computer Software shall be governed by this contract.

This clause applies to both existing and new uses of AI, both stand-alone AI and AI embedded within other systems or applications, AI developed both by the Agency or by third parties on behalf of Agencies for the fulfillment of specific agency missions, including relevant data inputs used to train AI and outputs used in support of decision making, and VA procurement of AI applications.

This clause does not apply to AI embedded within common commercial products, such as word processors or map navigation systems. The Contractor shall inform the VA Contracting Officer in writing if it believes the recommended and/or intended AI for use during contract performance is not covered by this clause. The burden to demonstrate the AI is a common commercial product shall rest solely with the Contractor.

Non-compliance with the terms above, or an accidental or purposeful loss of sensitive VA medical records information resulting from AI use, may result in Contractor liability to VA for any and all rights and remedies provided by law, including but not limited to contract termination, liquidated damages, and referral to VA's Suspension and Debarment Committee. The entire definition of VA Sensitive Data can be found at 38 U.S.C. § 5727 (23). The Contractor shall protect VA Sensitive data from unauthorized disclosure or use, and from being used to train or improve the functionality of the vendor's commercial offerings without express written permission from VA.

The Contractor shall include the substance of this clause in all subcontracts, including subcontractors at any tier and affiliates.

6.7 GENERATIVE ARTIFICIAL INTELLIGENCE REQUIREMENTS

If Artificial Intelligence is part of the Contractor system/solution, the Contractor shall be in compliance with E.O. 13960 and 14319, OMB Memorandums M-25-21, M-25-22, and M-26-04, and VA Directive and Handbook 6500 to support VA in trustworthy, secure, unbiased, and accountable AI innovation and ensure alignment with federal policies. Additionally, the Contractor shall support VA ensuring responsible AI, responsible use of AI, AI generated custom-developed code sharing and reusability (e.g. compliance with the SHARE IT Act), and AI Risk Management.

No web-based, publicly available generative AI service has been approved for use with VA-sensitive data, i.e. OpenAI's ChatGPT, Microsoft's Copilot, Google's Gemini, and Anthropic's Claude, among others. No PII, protected health information (PHI), or VA-sensitive data should be entered into these unapproved services. The entire definition of VA Sensitive Data can be found at 38 U.S.C. § 5727 (23).

The Contractor shall ensure that all AI Systems, including Large Language Models (LLM), whether standalone LLMs or integrated into broader software platforms, procured under this effort and/or used in performance of this contract complies with the Unbiased AI Principles as defined in Executive Order 14319 and OMB Memorandum M-26-04, e.g. Truth Seeking and Ideologically Neutral, as applicable to the intended use of the system.

The Contractor shall ensure that AI System/LLM generated outputs are truthful in responding to user prompts seeking factual information or analysis, prioritize historical accuracy, scientific inquiry, and objectivity, as well as acknowledge uncertainty where reliable information is incomplete or contradictory and do not fabricate, hallucinate, or present unverifiable information as fact.

The Contractor shall ensure that LLMs and AI outputs are neutral, nonpartisan tools that do not manipulate responses in favor of ideological dogmas such as DEI. The Contractor shall ensure that the LLMs, including the AI System, are not intentionally encoded with partisan or ideological judgments within an AI System's/LLM's outputs unless those judgments are prompted by or otherwise readily accessible to the end user.

Compliance with the AI requirements of this contract, including adherence to the Unbiased AI Principles, Truth-Seeking and Ideological Neutrality requirements, disclosure obligations, monitoring and reporting requirements, and corrective action responsibilities, is a material condition of eligibility for payment and continued performance. In accordance with OMB Memorandum M-26-04, failure to comply with these requirements, or refusal to take timely and appropriate corrective action to remedy identified noncompliance, may constitute a material breach of contract and may result in remedies consistent with the terms of the contract and applicable law including but not limited to withholding of payment, termination for cause/default, off-ramping, or other appropriate contractual remedies, as determined by the Contracting Officer.

6.7.1 AI SYSTEM/LLM DEVELOPMENT AND OPERATION DOCUMENTATION REQUIREMENTS

To enable Government continued assessment of compliance with Trustworthy AI requirements and both Unbiased AI Principles, Truth-seeking and Ideological Neutrality, in accordance with OMB M-26-04, the Contractor shall provide AI System/LLM Development and Operation documentation to include, at a minimum:

1. Acceptable Use Policy

The Contractor shall provide an Acceptable Use Policy document governing its AI operation that characterizes and differentiates appropriate and inappropriate use of their product offering

2. Model Cards, System Cards and/or Data Cards

The Contractor shall provide documentation describing essential information about the model, system, and or data as it relates to the AI/LLM product offering. The documentation shall address summaries of training process, identified risks and mitigations, and model evaluation scores on LLM benchmarks at a minimum, where appropriate

3. End User Resources

The Contractor shall provide documentation to include product tutorials, developer guides, and/or other tools to assist VA in ensuring proper use of the AI/LLM to maximize utility

4. Mechanism for End User Feedback

The Contractor shall provide documentation describing the mechanism employed to provide feedback to the Offeror on outputs identified that violate the Unbiased AI Principles. This may be satisfied by a general inbox, specific Point of Contact, or similar feedback mechanism.

5. Pre-Training and Post-Training Activities of the AI System/LLM

The Contractor shall provide documentation of Pre-Training and Post Training Activity that provides details on:

- a. Actions taken that impact the factuality and grounding of AI System/LLM outputs
- b. System-level prompts that provide natural language instructions to the model specifying guidelines on responding to user-generated queries, to include how a model responds when reliable information is incomplete, contradictory, or subject to individual interpretation
- c. The type of outputs restricted via content moderation and safety filters
- d. The use of red teaming as a means of continuously assessing the model to protect against incidents of bias in generated output.
- e. Training or development, if any, that occurred outside the United States, to include the type of activity and the country in which it occurred.
- f. Any modifications or configurations undertaken to comply with any regulation from a government other than the U.S. Federal Government.

6. Model Evaluation Results and Methodologies

The Contractor shall provide documentation describing the Evaluation Results of bias evaluations conducted by the Vendor to include the methodology for performing such tests (e.g., testing prompt pairs for politically-oriented topics).

The documentation shall also include Benchmark scoring results measuring the model's bias, helpfulness, honesty, or accuracy when provided with ambiguous versus straightforward questions, including any benchmarks comparing performance across multiple languages, where applicable.

7. Description of Enterprise-Level Controls

The Contractor shall provide documentation describing the Enterprise Governance tools and controls, such as:

- a. Customizable system instructions that are additive to a base model's system prompts or content generation filters.

- b. Product features that require a model to cite sources of its outputs or otherwise provide visibility into the provenance of the model's outputs.
- c. AI System/LLM model evaluation tools that enable comparisons either between a model's outputs, or across various models.

8. Third Party Modification Disclosure

The Contractor shall disclose of any additional controls to modify an AI Model's/LLM's output applied by the Contractor if the Contractor is not a direct developer of the LLM (e.g., classifiers, system prompts, fine-tuning, content moderation and filters)

Deliverable:

- A. AI System/LLM Development and Operation Documentation Package

6.7.2 MONITORING, REPORTING, AND CORRECTIVE ACTION

The Contractor shall develop and implement a Compliance Monitoring and Reporting Plan supporting ongoing monitoring processes to evaluate AI outputs for compliance with Trustworthy AI and Unbiased AI principles. This plan shall include a mechanism for authorized users to provide end user feedback to report suspected violations of Truth-Seeking or Ideological Neutrality requirements.

The Contractor shall notify the COR within ten (10) business days of identifying any material deviation from these principles and shall submit a written Corrective Action Plan describing mitigation steps, responsible parties, and timelines. Any material deviation, corrective action, and results shall be detailed in the Monthly Report in accordance with Section 5.3.3.1 of this PWS.

Deliverables:

- A. Compliance Monitoring and Reporting Plan
- B. Corrective Action Plan

6.7.3 MODEL UPDATES AND CHANGE NOTIFICATION

The Contractor, in an AI Model/LLM Change Disclosure, shall notify the Government throughout the PoP in advance of any material changes to AI models, including new AI enhancements, features and/or components, controls, retraining, classifiers, system prompts, fine-tuning, content moderation, filters, version replacement, or architectural changes, that could reasonably affect compliance with Trustworthy AI or Unbiased AI principles. Updated documentation shall be provided to VA prior to implementation of such changes.

Deliverable:

- A. AI Model/LLM Change Disclosure

ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED**A1.0 Cyber and Information Security Requirements for VA IT Services**

The Contractor shall ensure adequate LAN/Internet, data, information, and system security in accordance with VA standard operating procedures and standard PWS language, conditions, laws, and regulations. The Contractor's firewall and web server shall meet or exceed VA minimum requirements for security. All VA data shall be protected behind an approved firewall. Any security violations or attempted violations shall be reported to the VA Program Manager and VA Information Security Officer as soon as possible. The Contractor shall follow all applicable VA policies and procedures governing information security, especially those that pertain to assessment and authorization and continuous monitoring.

Contractor supplied equipment, PCs of all types, equipment with hard drives, etc. for contract services must meet all security requirements that apply to Government Furnished Equipment (GFE) and Government Owned Equipment (GOE). Security Requirements include: a) VA Approved Encryption Software must be installed on all laptops or mobile devices before being placed into operation, b) Bluetooth equipped devices are prohibited within VA; Bluetooth must be permanently disabled or removed from the device, unless the connection uses FIPS 140-2 (or its successor) validated encryption, c) VA approved anti-virus and firewall software, d) Equipment must meet all VA sanitization requirements and procedures before disposal. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems.

Each documented initiative under this contract incorporates VA Handbook 6500.6, "Contract Security," March 12, 2010 (Appendix C updated April 22, 2024) by reference as though fully set forth therein. The VA Handbook 6500.6, "Contract Security" shall also be included in every related agreement, contract, or order. The VA Handbook 6500.6, Appendix C, is included in this document as Addendum B.

Training requirements: The Contractor shall complete all mandatory training courses on the current VA training site, the VA Talent Management System (TMS) 2.0, and will be tracked therein. The TMS 2.0 may be accessed at <https://www.tms.va.gov/SecureAuth35/>. If you do not have a TMS 2.0 profile, go to <https://www.tms.va.gov/SecureAuth35/> and click on the "Create New User" link on the TMS 2.0 to gain access.

Contractor employees shall complete a VA Systems Access Agreement if they are provided access privileges as an authorized user of the computer system of VA.

A2.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at <http://www.ea.oit.va.gov/index.asp> in force at the time of issuance of this contract, including the Program Management Plan and VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance.

A2.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA's Web Governance if the Contractor's work includes building and maintaining VA's digital presence. This pertains, but is not limited to: websites, social media, creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

VA Web Governance website can be found at [Home - VA Web Governance](#).

A3.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

A3.1. Section 508 – Information and Communication Technology (ICT) Standards

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](#). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with "508 Chapter 2: Scoping Requirements" for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☐ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

A3.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A3.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

A4.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

1. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
2. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.
3. Smoking is prohibited inside/outside any building other than the designated smoking areas.
4. Possession of weapons is prohibited.
5. The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

A5.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (ePHI) that is subject to protection under the regulations issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and

164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and ePHI.

1. The Contractor will have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
2. The VA CO will be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.
3. Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.
4. Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.
5. Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.
6. Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with published procedures to protect the privacy and confidentiality of such information as required by VA.
7. Contractor must adhere to the following:
 - a. The use of "thumb drives" or any other medium for transport of information is expressly prohibited.

- b. Controlled access to system and security software and documentation.
 - c. Recording, monitoring, and control of passwords and privileges.
 - d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
 - e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
 - f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
 - g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
 - h. Contractor does not require access to classified data.
8. Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
9. VA Form 0752 shall be completed by all Contractor employees working on this contract and shall be provided to the CO before any work is performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

A6.0 Information Technology Using Sustainable Products and Services

Not Applicable.

**ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/
PRIVACY LANGUAGE**

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS FROM: *VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE*

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

- a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General. The primary clause used to define computer software license (not data/intellectual property first produced under this Contractor or order) is FAR 52.227-19, Commercial Computer Software License.
- b. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- c. VA information will not be co-mingled with any other data on the Contractor’s information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- d. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to Contractor and Subcontractor staff associated with the

contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.

- e. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- f. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- g. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- h. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- i. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.
- k. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt

of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.

- l. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- m. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- n. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- o. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- p. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of the VA CO.

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of Contractor/Subcontractor and agent of Contractor/Subcontractor.

- b. Contractors and subcontractors shall sign the VA Information Security Rule of Behavior (ROB) before access is provided to VA information and information systems (see Section 4, Training, below). The ROB contains the minimum user compliance requirements and does not supersede any policies of VA facilities or other agency components which provide higher levels of protection to VA's information or information systems. Users who require privileged access shall complete the VA elevated privilege access request processes before privileged access is granted.
- c. All Contractors and Subcontractors working with VA information are subject to the same security investigative and clearance requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors shall be in accordance with VA Directive and Handbook 0710, Personnel Suitability and Security Program. The Office of Human Resources and Administration/Operations, Security and Preparedness (HRA/OSP) is responsible for these policies and procedures. Contract personnel who require access to classified information or information systems shall have an appropriate security clearance. Verification of a Security Clearance shall be processed through the Special Security Officer located in HRA/OSP. Contractors shall conform to all requirements stated in the National Industrial Security Program Operating Manual (NISPOM).
- d. All Contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All Contractors and Subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the Contractor must state where all non-U.S. services are provided. The Contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.
- e. The Contractor shall notify the COR/CO in writing immediately (no later than 24 hours) after personnel separation or occurrence of other causes. Causes may include the following:
 - (1) Contractor/Subcontractor personnel no longer has a need for access to VA information or VA information systems.
 - (2) Contractor/Subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.
 - (3) Contractor believes their own personnel or Subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes Contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.

- (4) Any previously undisclosed changes to Contractor/Subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.
 - (5) Contractor/Subcontractor personnel have their authorization to work in the United States revoked.
 - (6) Agreement by which Contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for Contractor personnel.
- f. In such cases of contract fulfillment, termination, or other causes; the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by Contractor/Subcontractor personnel. These measures include (but are not limited to): removing and then securing Personal Identity Verification (PIV) badges and PIV – Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens. Contractors shall notify the appropriate VA COR/CO immediately to initiate access removal.
 - g. Contractors/Subcontractors who no longer require VA accesses will return VA-issued property to VA. This property includes (but is not limited to): documents, electronic equipment, keys, and parking passes. PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the appropriate VA COR/CO.

B4. TRAINING

- a. All contractors and subcontractors requiring access to VA information and VA information systems shall successfully complete the following before being granted access to VA information and its systems:
 - (1) VA Privacy and Information Security Awareness and Rules of Behavior course (Talent Management System (TMS) #10176) initially and annually thereafter.
 - (2) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the Organizational Rules of Behavior, relating to access to VA information and information systems initially and annually thereafter; and
 - (3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system or information access [to be defined by the VA program official and provided to the VA CO for inclusion in the solicitation document – i.e., any role-based information security training].

- b. The Contractor shall provide to the COR/CO a copy of the training certificates and certification of signing the Organizational Rules of Behavior for each applicable employee within five days of the initiation of the contract and annually thereafter, as required.
- c. Failure to complete the mandatory annual training is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the required training is complete.

B5. SECURITY INCIDENT INVESTIGATION

- a. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- c. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- d. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.

- e. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
- f. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
- g. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- h. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

- a. Information systems designed or developed on behalf of VA at non-VA facilities shall comply with all applicable Federal law, regulations, and VA policies. This includes standards for the protection of electronic Protected Health Information (PHI), outlined in 45 C.F.R. Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500 and VA Trusted Internet Connections (TIC) Architecture).
- b. Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA Information Security Knowledge Service to obtain an Authority to Operate (ATO). VA Directive 6517, Risk Management Framework for Cloud Computing Services, provides the security and privacy requirements for cloud environments.

- c. VA IT Contractors, Subcontractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500, VA Handbook 6517, Risk Management Framework for Cloud Computing Services and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO to identify the VA organization responsible for governance or resolution. Contractors shall comply with FAR 39.1, specifically the prohibitions referenced.
- d. The Contractor (including producers and resellers) shall comply with Office of Management and Budget (OMB) M-26-05 when using third-party software on VA information systems or otherwise affecting the VA information. This includes new software purchases and software renewals for software developed or modified by major version change after the issuance date of M-26-05 (January 23, 2026). The term "software" includes firmware, operating systems, applications and application services (e.g., cloud-based software), as well as products containing software. The Contractor shall provide a self-attestation that secure software development practices are utilized as outlined by Executive Order (EO) 14028 and NIST Guidance. A third-party assessment provided by either a certified Federal Risk and Authorization Management Program (FedRAMP) Third Party Assessor Organization (3PAO) or one approved by the agency will be acceptable in lieu of a software producer's self-attestation.
- e. The Contractor shall ensure all delivered applications, systems and information systems are compliant with Homeland Security Presidential Directive (HSPD) 12 and VA Identity and Access management (IAM) enterprise identity management requirements as set forth in OMB M-19-17, M-05-24, FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor), M-21-31 and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.
- f. The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with VA Handbook 6500, VA Information Security Knowledge Service, IAM enterprise requirements and NIST 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and/or trust-based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV and/or Common Access Card (CAC), as determined by the business need and compliance with VA Information Security Knowledge Service specifications.
- g. The Contractor shall use VA authorized technical security baseline configurations and certify to the COR that applications are fully functional and operate correctly as intended on systems in compliance with VA baselines prior to acceptance or connection into an authorized VA computing environment. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may configure to

comply with that STIG. If VA determines a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to develop the configuration settings. FAR 39.1 requires the population of operating systems and applications includes all listed on the NIST National Checklist Program Checklist Repository,

- h. The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default "program files" directory with silently install and uninstall. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.
- i. Applications designed for normal end users will run in the standard user context without elevated system administration privileges.
- j. The Contractor-delivered solutions shall reside on VA approved operating systems. Exceptions to this will only be granted with the written approval of the COR/CO.
- k. The Contractor shall design, develop, and implement security and privacy controls in accordance with the provisions of VA security system development life cycle outlined in NIST 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, VA Directive and Handbook 6500, and VA Handbook 6517.
- l. The Contractor shall comply with the Privacy Act of 1974 (the Act), FAR 52.224-2 Privacy Act, and VA rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish a VA function.
- m. The Contractor shall ensure the security of all procured or developed information systems, systems, major applications, minor applications, enclaves and platform information technologies, including their subcomponents (hereinafter referred to as "Information Systems") throughout the life of this contract and any extension, warranty, or maintenance periods. This includes security configurations, workarounds, patches, hotfixes, upgrades, replacements and any physical components which may be necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems (including systems, operating systems, products, hardware, software, applications and firmware). The Contractor shall ensure security fixes do not negatively impact the Information Systems.
- n. When the Contractor is responsible for operations or maintenance of the systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA Information Security Knowledge Service. When security fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the Contractor shall provide written

notice to the VA COR/CO that the patch has been validated as to not affecting the Systems within 10 business days.

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.
- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.
- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).
- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above

assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.

- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.
- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.
- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.
- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will

include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.

- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the information security, network or system requirements mandated in the agreement between VA and the Contractor.
- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b): interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.
- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any

such security reports or other related assessments, upon completion and validation.

- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- a. The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall attest that equipment procured from an OEM or authorized reseller or distributor are authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.
- c. All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.
- d. If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information

Administration (NTIA) report “The Minimum Elements for a Software Bill of Materials (SBOM).”

- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B10. VIRUSES, FIRMWARE, AND MALWARE

- a. The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- b. The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.
- c. The Contractor shall provide or arrange for the provision of technical justification as to why any “false positive” hit has taken place to ensure their code’s supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.
- d. The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter “virus or other malware”) onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:
 - (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA’s information networks, computer systems and information systems; and
 - (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B11. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor's products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B12. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation will include information regarding the following:
 - (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
- c. The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses for their products and services within 30 days of discovery. Updates to remediate critical or emergent vulnerabilities will be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.
- d. The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered

vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment will be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds will be provided to the COR/CO before the above deadlines.

B13. SPECIALIZED DEVICES/SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING)

- a. Contractor supplies/delivered Medical Devices, Special Purpose Systems-Operational Technology (SPS-OT) and Research Scientific Computing Devices shall comply with all applicable Federal law, regulations, and VA policies. New developments require creation, testing, evaluation, and authorization in compliance with processes specified on the Specialized Device Cybersecurity Department Enterprise Risk Management (SDCD-ERM) Portal, VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, VA Handbook 6500, and the VA Information Security Knowledge Service. Deviations from Federal law, regulations, and VA Policy are identified and documented as part of VA Directive 6550 and/or the VA Enterprise Risk Analysis (ERA) processes for Specialized Devices/Systems processes.
- b. All Contractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500 and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO for governance or resolution.
- c. The Contractor shall certify to the COR/CO that devices/systems that have completed the VA Enterprise Risk Analysis (ERA) process for Specialized Devices/Systems are fully functional and operate correctly as intended. Devices/systems must follow the VA ERA authorized configuration prior to acquisition and connection to the VA computing environment. If VA determines a new VA ERA needs to be created, the Contractor shall provide required technical support to develop the configuration settings. Major changes to a previously approved device/system will require a new ERA.
- d. The Contractor shall comply with all practices documented by the Food Drug and Administration (FDA) Premarket Submission for Management of Cybersecurity in Medical Devices and Postmarket Management of Cybersecurity in Medical Devices.
- e. The Contractor shall design devices capable of accepting all applicable security patches with or without the support of the Contractor personnel. If patching can only be completed by the Contractor, the Contractor shall commit the resources

needed to patch all applicable devices at all VA locations. If unique patching instructions or packaging is needed, the Contractor shall provide the necessary information in conjunction with the validation/testing of the patch. The Contractor shall apply security patches within 30 business days of the patch release and have a formal tracking process for any security patches not implemented to include explanation when a device cannot be patched.

- f. The Contractor shall provide devices able to install and maintain VA-approved antivirus capabilities with the capability to quarantine files and be updated as needed in response to incidents. Alternatively, a VA-approved whitelisting application may be used when the Contractor cannot install an anti-virus / anti-malware application.
- g. The Contractor shall verify and document all software embedded within the device does not contain any known viruses or malware before delivery to or installation at a VA location.
- h. Devices and other equipment or systems containing media (hard drives, optical disks, solid state, and storage via chips/firmware) with VA sensitive information will be returned to the Contractor with media removed. When the contract requires return of equipment, the options available to the Contractor are the following:
 - (1) The Contractor shall accept the system without the drive, firmware and solid state.
 - (2) VA's initial device purchase includes a spare drive or other replacement media which must be installed in place of the original drive at time of turn-in; or
 - (3) Due to the highly specialized and sometimes proprietary hardware and software associated with the device, if it is not possible for VA to retain the hard drive, firmware, and solid state, then:
 - (a) The equipment Contractor shall have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact.
 - (b) Any fixed hard drive, Complementary Metal-Oxide-Semiconductor (CMOS), Programmable Read-Only Memory (PROM), solid state and firmware on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the solicitation, contract, or order.

B14. DATA CENTER PROVISIONS

- a. The Contractor shall ensure the VA network is accessed by in accordance with VA Directive 6500 and IAM security processes specified in the VA Information Security Knowledge Service.
- b. The Contractor shall ensure network infrastructure and data availability in accordance with VA information system business continuity procedures specified in the VA Information Security Knowledge Service.
- c. The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards or encrypted tunnels).
- d. The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic will traverse the network.
- e. The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.
- f. The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive and Handbook 6513, and MOU/ISA process specified in the VA Information Security Knowledge Service.